

RAPPORT DE SÉCURITÉ

DevSecOps Zero Trust Pipeline

Build #41 — 23 May 2026 à 20:27

Étape	Outil	Résultat	Statut
SAST	Semgrep	1 finding(s)	■■
SCA	Trivy	0 CVE (0 CRITICAL / 0 HIGH)	■
DAST	OWASP ZAP	1 alerte(s)	■■
IA	Anti-Tampering	Pipeline vérifié	■
BUILD	Docker	zerotrust-app:41	■
SIGN	Cosign	Signature keyless appliquée	■

1 — Analyse Statique (SAST — Semgrep)

Fichier	Règle / Check ID	Sévérité	Ligne
test-app/app.py	.audit.app-run-param-config.avoid_app_run_with_bad_host	WARNING	117

2 — Analyse des Dépendances (SCA — Trivy)

■ Aucune CVE détectée.

3 — Remédiation IA des CVE (Claude Haiku)

CVE	Package	Priorité	Correction requirements.txt
CVE-2023-50447	Pillow	CRITICAL	Pillow>="10.2.0"
CVE-2023-44271	Pillow	HIGH	Pillow<="10.0.0"
CVE-2023-4863	Pillow	HIGH	Pillow>="10.0.1"
CVE-2024-28219	Pillow	HAUTE	Pillow>=10.3.0

4 — Analyse Dynamique (DAST — OWASP ZAP)

Niveau de risque	Nombre d'alertes
Low	1

Alerte	Risque	Confiance	Instances
Server Leaks Version Information via "Server" HTTP Response Heade	Low	3	3

5 — Build Docker & Signature Cosign

Propriété	Valeur
Image Docker	zerotrust-app:41
Build number	41
Date	23/05/2026 à 20:27:02
Base image	python:3.11-slim (Debian 13)
Utilisateur runtime	appuser (non-root — Zero Trust)
Signature	Cosign v3 — keyless OIDC (fallback local)
Scan image	Trivy — exit-code 0 (résultats archivés)